تام المالية
TAM CAPITAL

CYBER SECURITY POLICY

V1_APR 2025

Approved by:	**Board of Directors**
Date:	[22/04/2025] (Stamp)

Document Control

Prepared By	Head of IT / Information Security Officer / Head of Risk
Reviewed By	CEO
Endorsed By	Executive Committee
Approved By	Board of Directors
Custodian	

Change Control

Ver.	Date	Brief Description of Changes
1		Initial Document

Issue Control

Sr. No.	Copy Holders
1	Board of Directors
2	Executive Committee
3	CEO
4	Head of IT / Information Security Officer
5	Head of Risk

TABLE OF CONTENTS

Clause #	Subject	Page #
1	**INTRODUCTION**	4
2	**REFERENCE TO REGULATIONS & OTHER INTERNAL DOCUMENTS**	4
3	**POLICY STATEMENTS**	5
3.1	**VPN Policy**	5
3.2	**Wireless Policy**	6
3.3	**Network Security Policy**	7
3.4	**Confidential Data Policy**	9
3.5	**Email Policy**	11
3.6	**IT Outsource Policy**	14
3.7	**Password Policy**	19
4	**AMENDMENT TO THE POLICY**	22

1. INTRODUCTION

The Cyber Security Policy has been approved by the Board of Directors ("Board") of Tam Capital ("Company"). It represents an enforceable document and is an integral part of Company's IT and IS policies.

Cybersecurity is the practice of protecting systems, networks, and data from cyber threats such as hacking, malware, phishing, and data breaches. It involves a combination of technologies, processes, and policies designed to safeguard digital assets from unauthorized access, disruption, or damage.

Cybersecurity threats come from various sources, including hackers, cybercriminals, insider threats, and state-sponsored attackers. These threats can result in financial loss, reputational damage, and legal consequences. To mitigate risks, organizations implement security measures such as firewalls, encryption, multi-factor authentication, and security awareness training. Tam Capital deals with different information such as valuable client information, investment and financial information and hence, with increasing cyber security threats, any cyber-attack on its systems and breach of information can harm the Company's reputation and affect the Company financially, legally and operationally.

The purpose of this policy is to establish and develop a very effective cyber security framework, and adopt cyber security standards that mitigate the associated risks of cyber-attacks and information breach.

2. REFERENCE TO OTHER DOCUMENTS

The policy may be read in conjunction with following regulations and internal documents:

- Capital Market Law
- Capital Market Institutions Regulations
- IT Policy
- Risk Policy
- Other relevant documents

3. POLICY STATEMENTS

3.1 Virtual Private Network (VPN) Policy

A Virtual Private Network (VPN) is a mechanism that provides a secure connection over unsecured or public networks to protected network resources (usually internal corporate networks).

The Company's provides a Virtual Private Network (VPN) that enables users to securely access network resources and Data center from external computers or devices. The VPN provides several benefits to the organization and its constituents, including:

- The protection of communications and transmissions between the user and organizational systems
- The protection of sensitive organizational systems and information from unauthorized access
- Greater control by the organization over network traffic access and routing, increasing the efficiency and security of activities performed through the VPN

Any machine, personal or otherwise externally owned or operated, that connects to the Company's network through the VPN is considered an extension of network and is subject to the same standards and rules that cover company-owned equipment.

- Use of the VPN is subject to the Company's Acceptable Usage Policies for Internet use, e-mail, and any other traffic over the protected connection.

- VPN users must ensure that any computer through which they access the VPN (including personal computers, if applicable) are provisioned with and running antivirus software. Antivirus software should be consistent with the corporate standards and reflect the latest available updates.

- Any user who accesses the Company's internal network through the VPN from a personal computer or any other computer that is not owned by the Company must ensure that the external device is configured in compliance with the Company's VPN and network access policies.

- Access and Authentication:

    - VPN access must be controlled through a user authentication mechanism.
    - Users may not share their VPN login credentials and should take all reasonable efforts to avert accidental disclosure of login credentials.

- Managers may not assign or encourage the use of group login credentials through which more than one individual may access the systems under single user identity.
- Users may not employ artificial processes to keep VPN connection open during idle periods longer than 5mins.
- Only approved clients may be used for VPN access to internal networks. Unapproved and user-created VPN connections will not be permitted on the internal network.

- VPN configuration and management

  - The VPN will be configured and managed by the Network / security admin of IT dept. of the Company.
  - The VPN must be configured to automatically disconnect after 5 mins of inactivity.
  - The VPN must be configured so that, when the user is connected via the VPN to the corporate network, all network traffic to and from the PC will be forced through the VPN tunnel. All other traffic will be dropped.
  - The VPN does not replace general Internet access or ISP-provided services. Users who require Internet service for legitimate work responsibilities must separately manage those services.
  - All incoming and outgoing traffic via VPN must be monitored and logged with weekly validations of the VPN traffic by the network and security administrators.

Violation of this policy may result in disciplinary action which may include performance sanctions; termination for employees and temporaries; a termination of employment relations in the case of contractors or consultants; dismissal for interns and volunteers. Additionally, individuals are subject to restriction or suspension of the Company's VPN privileges, as well as civil and criminal prosecution.

3.2 Wireless Policy

Wireless networks enable computers to be interconnected using standard network protocols such as IP. Wireless networking technology relies on radio frequencies and data transmission.

The purpose of this policy is to secure and protect the information assets owned by the Company. The Company provides computer devices, networks, and other electronics information systems to meet missions, goals, and initiatives. The Company grants access to these resources as a privilege and must manage them responsibly to maintain the confidentiality, integrity and availability of all information assets. This policy specifies the conditions that wireless infrastructure device must satisfy to connect to the Company's network.

General Network Access Requirements

- Limited accessibility on all wireless routers
- Be installed, supported, and maintained by the Company's network administrator
- Use the Company's approved authentication protocols and infrastructure
- Use the Company's approved encryption protocols
- Maintain a hardware address that can be registered and tracked
- Not interfere with wireless access deployments maintained by other supporting organizations
- Lab device Service Set Identifier (SSID) must be different from the Company's production device SSID

Authentication Protocol Requirements

- Must Enable WiFi Protected Access Pre-shared Key (WPA-PSK), EAP-FAST, PEAP, or EAP-TLS
- When enabling WPA-PSK, configure a complex shared secret key on the wireless client and the wireless access point
- Accessibility authentication (User Name and Password) of each router should be changed every quarter.

Configuration requirements

- Disable broadcast of SSID
- Change the default SSID name
- Change the default login and password

Violation of this policy may result in disciplinary action which may include performance sanctions; termination for employees and temporaries; a termination of employment relations in the case of contractors or consultants; dismissal for interns and volunteers. Additionally, individuals are subject to restriction or suspension of the Company's wireless privileges, as well as civil and criminal prosecution.

3.3 Network Security Policy

A network security policy is a generic document that outlines rules for computer network access, determines how policies are enforced and lays out some of the basic architecture of the company security/ network security environment.

The goal of network security is to support the network and computer business requirements, using methods that reduce risk. Security policies describe what you must secure, and the ways

you secure them, to support your business or mission. Firewalls, intrusion detection systems (IDS), intrusion protection systems (IPS), anti-virus (AV), backup and restore strategies, locked doors, and system administration checklists are all some of the things you might use. Security policies provide the blueprint for using them: the what, how, why, when, and by whom.

Following policies are covered under the Network Security Policy.

Analog/ISDN Line Policy

- The fax/print machine must be placed in a centralized administrative area designated for departmental use, and away from other computer equipment.
- A computer which is capable of making a fax connection is not to be allowed to use an analog line for this purpose.
- The line will be used solely fax communication for the Company's business, and not for personal reasons.

Router Security Policy

Every router must meet the following configuration standards:

- No local user accounts are configured on the router.
- The enabled password on the router must be kept in a secure encrypted form. The router must have the enabled password set to the current production router password from the router's support organization.
- Disallow the following:
    - IP directed broadcasts
    - Incoming packets at the router sourced with invalid addresses
    - TCP small services
    - UDP small services
    - All source routing
    - All web services running on router

- Use corporate standardized community strings.
- Access rules are to be added as business needs arise.
- The router must be included in the corporate enterprise management system with a designated point of contact.
- Each router must have the following statement posted in clear view:
  "UNAUTHORIZED ACCESS TO THIS NETWORK DEVICE IS PROHIBITED. YOU MUST HAVE EXPLICIT PERMISSION TO ACCESS OR CONFIGURE THIS DEVICE. ALL ACTIVITIES PERFORMED ON THIS DEVICE MAY BE LOGGED, AND VIOLATIONS OF THIS POLICY MAY RESULT IN DISCIPLINARY ACTION, AND MAY BE REPORTED TO LAW ENFORCEMENT. THERE IS NO RIGHT TO PRIVACY ON THIS DEVICE."

Violation of this policy may result in disciplinary action which may include performance sanctions; termination for employees and temporaries; a termination of employment relations in the case of contractors or consultants; dismissal for interns and volunteers. Additionally, individuals are subject to restriction or suspension of the Company's wireless privileges, as well as civil and criminal prosecution.

3.4 Confidential Data Policy

This policy is to identify information that is considered confidential and to establish the principles and guidelines on the access, maintenance and handling of such confidential information.

The Confidential Data Policy is intended to help employees determine what information can be disclosed to employees/non-employees, as well as the relative sensitivity of information that should not be disclosed outside of the Company without proper authorization. Such data should not be copied to or removed from the institution's operational control without department head's permission.

The information covered in these guidelines includes, but is not limited to, information that is either stored or shared via any means. This includes: electronic information, information on paper, and information shared orally or visually (such as telephone and video conferencing).

All employees should familiarize themselves with the information labeling and handling guidelines that follow this introduction. It should be noted that the sensitivity level definitions were created as guidelines and to emphasize common sense steps that you can take to protect the Company's confidential information.

The Sensitivity Guidelines below provides details on how to protect information at varying sensitivity levels.

Minimal Sensitivity:

General corporate information; some personnel and technical information

Access:
The Company's Employees, Outsourced Staff, Interns, Contractors, Vendors, Volunteers and people with a business need to know.

Distribution within the Company:
Approved electronic mail and electronic file transmission methods.

Distribution outside the Company's internal mail:
Approved electronic mail and electronic file transmission methods.

Electronic distribution:
No restrictions except that it is sent to only approved recipients.

Storage:
Keep from view of unauthorized people; erase whiteboards, do not leave in view on tabletop. Machines should be administered with security in mind. Protect from loss; electronic information should have individual access controls where possible and appropriate.

Disposal/Destruction:
Electronic data should be expunged /cleared. Reliably erase or physically destroy media.

More Sensitive:

Business, financial, technical, and most personnel information

Access:
The Company's employees and non-employees with signed non-disclosure agreements who have a business need to know.

Distribution within the Company:
Approved electronic mail and electronic file transmission methods.

Distribution outside the Company's internal mail:
Approved private carriers.

Electronic distribution:
No restrictions to approved recipients within the Company, but should be encrypted or sent via a private link to approved recipients outside of the Company's premises.

Storage:
Individual access controls are highly recommended for electronic information.

Disposal/Destruction:
Electronic data should be expunged /cleared. Reliably erase or physically destroy media.

Most Sensitive:

Trade secrets & marketing, operational, personnel, financial, source code & technical information integral to the success of our company

Access: Only those individuals (Company's employees and non-employees) designated with approved access and signed non-disclosure agreements.

Distribution within the Company:
Delivered direct - signature required, envelopes stamped confidential, or approved electronic file transmission methods.

Distribution outside the Company's internal mail:
Delivered direct; signature required; approved private carriers.

Electronic Distribution:
There are no restrictions to approved recipients within the Company, but it is highly recommended that all information should be strongly encrypted.

Storage:
Individual access controls are very highly recommended for electronic information. Physical security is generally used, and information should be stored in a physically secured computer.

Disposal/Destruction:
Strongly Encouraged. In specially marked disposal bins on the Company's premises; electronic data should be expunged /cleared. Reliably erase or physically destroy media.

Violation of this policy may result in disciplinary action which may include performance sanctions; termination for employees and temporaries; a termination of employment relations in the case of contractors or consultants; dismissal for interns and volunteers. Additionally, individuals are subject to restriction or suspension of the Company's information access privileges, as well as civil and criminal prosecution.

3.5 E-mail Policy

This policy covers appropriate use of official email of the Company's. The purpose of this policy is to ensure the proper use of the Company's email system and make users aware of what the Company's deems as acceptable and unacceptable use of its email system.

Email is a business communication tool and users are obliged to use this tool in a responsible, effective and lawful manner. Although by its nature email seems to be less formal than other written communication, the same laws apply. Therefore, it is important that users are aware of the legal risks of e-mail:

- If you send emails with any libelous, defamatory, offensive, racist or obscene remarks, you can be held liable, the Company's as an entity is not responsible for such instances/occurrences.
- If you forward emails with any libelous, defamatory, offensive, racist or obscene remarks, you can be held liable, the Company's as an entity is not responsible for such instances/occurrences.
- If you unlawfully forward confidential information, you can be held liable, the Company's as an entity is not responsible for such instances/occurrences.
- If you unlawfully forward or copy messages without permission, you can be held liable for copyright infringement, The Company's as an entity is not responsible for such instances/ occurrences.
- If you send an attachment that contains a virus, you can be held liable, The Company's as an entity is not responsible for such instances/ occurrences.

By following the guidelines in this policy, the email user can minimize the legal risks involved in the use of e-mail. If any user disregards the rules set out in this Email Policy, the user will be fully liable and the Company will disassociate itself from the user as far as legally possible.

The following rules are required by law and are to be strictly adhered to:

- It is strictly prohibited to send or forward emails containing libelous, defamatory, offensive, racist or obscene remarks. If you receive an e-mail of this nature, you must promptly notify your supervisor.
- Do not forward a message without acquiring permission from the sender first.
- Do not send unsolicited email messages.
- Do not forge or attempt to forge email messages.
- Do not send email messages using another person's email account.
- Do not copy a message or attachment belonging to another user without permission of the originator.
- Do not disguise or attempt to disguise your identity when sending mail.

Prohibited Use

The Company's email system shall not to be used for the creation or distribution of any disruptive or offensive messages, including offensive comments about race, gender, color, disabilities, age, sexual orientation, pornography, religious beliefs and practice, political beliefs or national origin. Employees who receive any emails with this content from any the Company's employee should report the matter to their supervisor immediately.

The following activities are prohibited by the policy:

- Sending email that is intimidating or harassing.
- Using email for conducting personal business.

- Using email for purposes of political lobbying or campaigning.
- Violating copyright laws by inappropriately distributing protected works.
- Posing as anyone other than oneself when sending email, except when authorized to send messages for another when serving in an administrative support role.
- The use of unauthorized e-mail software.

The following activities are prohibited because they impede the functioning of network communications and the efficient operations of electronic mail systems:

- Sending or forwarding chain mails.
- Sending unsolicited messages to large groups except as required to conduct agency business.
- Sending excessively large messages
- Sending or forwarding email that is likely to contain computer viruses.

Personal Use

Although The Company's email system is meant for business use, the Company's allows the reasonable use of email for personal use if certain guidelines are adhered to.

- Personal use of email should not interfere with work.
- Personal emails must also adhere to the guidelines in this policy.
- Personal emails are kept in a separate folder, named 'Private'. The emails in this folder must be deleted weekly so as not to clog up the system.
- The forwarding of chain mails, junk mail, jokes and executables is strictly forbidden.
- On average, users are not allowed to send more than 2 personal emails a day.
- Do not send mass mailings.
- All messages distributed via the company's email system, even personal emails, are the Company's property.

Employees must exercise utmost caution when sending any email from inside the Company's to an outside network. Unless approved by System Administrator, The Company's email will not be automatically forwarded to an external destination. Sensitive information will not be forwarded via any means, unless that email is critical to business and is encrypted in accordance with the Acceptable Encryption Policy.

Violation of this policy may result in disciplinary action which may include performance sanctions; termination for employees and temporaries; a termination of employment relations in the case of contractors or consultants; dismissal for interns and volunteers. Additionally, individuals are subject to restriction or suspension of email privileges, as well as civil and criminal prosecution.

3.6 IT Outsource Policy

Outsourcing involves transferring responsibility for carrying out an activity (previously carried on internally) to an outsourcer for an agreed charge. The outsourcer provides services to the customer based on a mutually agreed service level, normally defined in a formal contract.

Many commercial benefits have been ascribed to outsourcing, the most common amongst these being:

- Reducing the organization's costs
- Greater focus on core business by outsourcing non-core functions
- Access to world-class skills and resources

Despite the potential benefits, information security incidents such as inappropriate access to or disclosure of sensitive information, loss of intellectual property protection or the inability of the outsourcer to live up to agreed service levels, would reduce the benefits and could jeopardize the security posture of the organization.

Further, these critical factors could lead to financial losses to the organization, especially in financial organizations. Such incidents would tarnish the company image in the market and ruin the confidence of the customers of the company which shakes the stability.

This policy specifies controls to reduce the information security risks associated with outsourcing.

The policy applies throughout the Company. Outsourcing providers (also known as outsourcers) include:

- Hardware and software support and maintenance staff
- External consultants and contractors
- IT or business process outsourcing firms
- Temporary staff

The policy addresses the following controls found in the ISO standards:

- Identification of risks related to external parties
- Addressing security when dealing with customers
- Addressing security in third party agreements

Criteria for selecting an outsourcer shall be defined and documented, taking into account the:

- company's reputation and history;
- quality of services provided to other customers;

- number and competence of staff and managers;
- financial stability of the company and commercial record;
- retention rates of the company's employees;
- quality assurance and security management standards currently followed by the company (e.g. certified compliance with ISO).

The IT department shall nominate a suitable owner from the IT team for each function/process outsourced. The owner, with help from the local Information Security Management Team shall assess the risks before the function/process is outsourced, using the Company's standard risk assessment processes.

In relation to outsourcing, specifically, the risk assessment shall take due account of the:

a) nature of logical and physical access to the Company's information assets and facilities required by the outsourcer to fulfill the contract;
b) sensitivity, volume and value of any information assets involved;
c) commercial risks such as the possibility of the outsourcer's business failing completely, or of them failing to meet agreed service levels or providing services to the Company's competitors where this might create conflicts of interest; and
d) Security and commercial controls known to be currently employed by the Company and/or by the outsourcer.

The result of the risk assessment with the business justification shall be presented to corporate management/director board, depending on the severity and financial volume of the project, for approval prior to signing the outsourcing contract. Executive management shall decide if the Company will benefit overall by outsourcing the function to the outsourcer, taking into account both the commercial and information security aspects. If the risks involved are high and the commercial benefits are marginal (e.g. if the controls necessary to manage the risks are too costly), the function shall not be outsourced.

Contracts and Confidentiality Agreements

A formal contract between the Company and the outsourcer shall exist to protect both parties. The contract shall clearly define the types of information exchanged and the purpose for so doing.

If the information being exchanged is sensitive, a binding confidentiality agreement shall be in place between the Company and the outsourcer, whether as part of the outsource contract itself or a separate non-disclosure agreement (which may be required before the main contract is negotiated).

Information shall be classified and controlled in according with the Company's policy. Any information received by the Company from the outsourcer who is bound by the contractor confidentiality agreement shall be protected by appropriate classification and labelling. Upon termination of the contract, the confidentiality arrangements shall be revisited to determine whether confidentiality has to be extended beyond the tenure of the contract. All contracts shall be submitted to the Legal for accurate content, language and presentation. The contract shall clearly define each party's responsibilities towards the other by defining the parties to the contract, effective date, functions or services being provided (e.g. defined service levels), liabilities, limitations on use of sub-contractors and other commercial/legal matters normal to any contract. Depending on the results of the risk assessment, various additional controls should be embedded or referenced within the contract, such as:

- Legal, regulatory and other third party obligations such as data protection/privacy laws, money laundering etc.; In the case of "offshore" outsourcing, special consideration must be given to the ramifications of transferring information between countries or jurisdictions, particularly where privacy and similar laws may conflict. Take qualified legal advice as a matter of course.
- Information security obligations and controls such as:
  - Information security policies, procedures, standards and guidelines, normally within the context of an Information Security Management System such as that defined in ISO;
  - Background checks on employees or third parties working on the contract;
  - Access controls to restrict unauthorized disclosure, modification or destruction of information, including physical and logical access controls, procedures for granting, reviewing, updating and revoking access to systems, data and facilities etc.;
  - Information security incident management procedures including mandatory incident reporting;
  - Return or destruction of all information assets by the outsourcer after the completion of the outsourced activity or whenever the asset is no longer required to support the outsourced activity;
  - Copyright, patents and similar protection for any intellectual property shared with the outsourcer or developed in the course of the contract;

- Specification, design, development, testing, implementation, configuration, management, maintenance, support and use of security controls within or associated with IT systems, plus source code escrow;
- Anti-malware, anti-spam and similar controls;
- IT change and configuration management, including vulnerability management, patching and verification of system security controls prior to their connection to production networks;
- The right of the Company's to monitor all access to and use of the Company's facilities, networks, systems etc., and to audit the outsourcer's compliance with the contract, or to employ a mutually agreed independent third party auditor for this purpose;
- Business continuity arrangements including crisis and incident management, resilience, backups and IT Disaster Recovery.
- Although outsourcers that are certified compliant with ISO can be presumed to have an effective Information Security Management System in place, it may still be necessary for the Company to verify security controls that are essential to address the Company's specific security requirements, typically by auditing them.

Hiring and training of employees

Outsource employees, contractors and consultants working on behalf of the Company shall be subjected to background checks equivalent to those performed on the Company's employees. Such screening shall take into consideration the level of trust and responsibility associated with the position and (where permitted by local laws):

- Proof of the person's identity (e.g. passport, iqama, ID);
- Proof of their academic qualifications (e.g. certificates);
- Proof of their work experience (e.g. résumé/CV and references);
- Criminal record check;
- Credit check.

Companies providing contractors/consultants directly to the Company or to outsourcers used by the Company shall perform at least the same standard of background checks as those indicated above.

Suitable information security awareness, training and education shall be provided to all employees and third parties working on the contract, clarifying their responsibilities relating to the Company's information security policies, standards, procedures and guidelines (e.g. privacy policy, acceptable use policy, procedure for reporting information security incidents etc.) and all relevant obligations defined in the contract.

Access Controls

In order to prevent unauthorized access to the Company's information assets by the outsourcer or sub-contractors, suitable security controls are required as outlined in this section. The details depend on the nature of the information assets and the associated risks, implying the need to assess the risks and design suitable control architecture.

Technical access controls shall include:

- User identification and authentication;
- Authorization of access, generally through the assignment of users to defined user roles having appropriate logical access rights and controls;
- Data encryption in accordance with the Company's encryption policies and standards defining algorithms, key lengths, key management and escrow etc.
- Accounting/audit logging of access checks, plus alarms/alerts for attempted access violations where applicable.

Procedural components of access controls shall be documented within procedures, guidelines and related documents and incorporated into awareness, training and educational activities. This includes:

- Choice of strong passwords;
- Determining and configuring appropriate logical access rights;
- Reviewing and if necessary revising access controls to maintain compliance with requirements;

Physical access controls shall include:

- Layered controls covering perimeter and internal barriers;
- Strongly-constructed facilities;
- Suitable locks with key management procedures;
- Access logging though the use of automated key cards, visitor registers etc.;
- Intruder alarms/alerts and response procedures;

If parts of the Company's IT infrastructure is to be hosted at a third party data centre, the data centre operator shall ensure that the Company's assets are both physically and logically isolated from other systems.

The Company shall ensure that all information assets handed over to the outsourcer during the course of the contract (plus any copies made thereafter, including backups and archives) are duly retrieved or destroyed at the appropriate point on or before termination of the contract. In the case of highly classified information assets, this normally requires the use of a schedule or register and a process whereby the outsourcer formally accepts accountability for the assets at the point of hand-over.

Security Audits

If the Company's IT has outsourced any of its operation to an outsourcer based at a different location, it shall audit the outsourcer's physical premises periodically for compliance to the Company's security policies, ensuring that it meets the requirements defined in the contract.

The audit shall also take into consideration the service levels agreed in the contract, determining whether they have been met consistently and reviewing the controls necessary to correct any discrepancies.

The frequency of audit shall be determined by management on advice from functions such as Internal Audit, Information Security Management and Legal.

3.7 Password Policy

Passwords are an important aspect of computer security in the Company's financial environment. A poorly chosen password may result in unauthorized access and/or exploitation of the Company's resources and information. All users, including contractors and vendors with access to the Company's systems, are responsible for taking the appropriate steps, as outlined below, to select and secure their passwords.

The purpose of this policy is to establish a standard for creation of strong passwords, the protection of those passwords, and the frequency of change.

The scope of this policy includes all personnel who have or are responsible for an account (or any form of access that supports or requires a password) on any system that resides at any the Company's facility, has access to the Company's network, or stores any internal / non-public Company information.

General

- All system-level passwords (e.g. Windows Administrator, application administration accounts, etc.) must be changed on at least a quarterly basis or immediately when an administrator leaves the organization or system access by a third party on maintenance.
- All production system-level passwords must be part of the Company's network administered password management database.
- All user level passwords (e.g., Client Platform, desktop computer, etc.) must be changed at least every three months. This functionality should be available in all applications hosted by the Company.
- User accounts that have system-level privileges granted through group memberships must have a unique password from all other accounts held by that user.
- Where SNMP - simple network management protocol is used, the community strings must be defined as something other than the standard defaults of "public," "private" and "system" and must be different from the passwords used to log in interactively. A keyed hash must be used where available. (Refer network policy for more details.)
- Passwords should not be written down, emailed or commonly shared.
- Passwords should not be compromised nor revealed to any other than the user himself.
- All password resets on software applications should be directed through the users email address.
- All user-level and system-level passwords must conform to the guidelines described below.

General Password Construction Guidelines

All users in the Company's should be aware of how to select strong passwords.

Strong passwords have the following characteristics:

- Password Complicity

  All user application (user interfacing layer) passwords must contain the following three character classes:
  - Lower case characters
  - Upper case characters
  - Numbers

  In addition to this operating system passwords can use the following classes optionally

  - Punctuation
  - Special characters

- Minimum Length of a Password:

  - Contain at least eight alphanumeric characters.
  - Passwords should not be repetitive or a set number of previous passwords must be not allowed to use (Eg: three previous passwords cannot be used).
  - Password Expiry: Password should be forcibly changed in every 90 days.
  - Unsuccessful Attempts: User ID should be disabled after 3 consecutive unsuccessful user attempts.

- Weak passwords have the following characteristics:

  - The password contains less than fifteen characters
  - The password is a word found in a dictionary (English or foreign)
  - The password is a common usage word such as:
    a) Names of family, pets, friends, co-workers, fantasy characters, etc.
    b) Computer terms and names, commands, sites, companies, hardware, software.
    c) Birthdays and other personal information such as addresses and phone numbers.
    d) Word or number patterns like aaabbb, qwerty, zyxwvuts, 123321, etc.
    e) Any of the above spelled backwards.
    f) Any of the above preceded or followed by a digit (e.g., secret1, 1secret)

- Password Protection Standards

  - Always use different passwords for the Company's accounts from other non-Company access (e.g., personal ISP account, option trading, benefits, etc.).
  - Always use different passwords for various Company's access needs whenever possible. For example, select one password for systems that use directory services (i.e. Active Directory etc.) for authentication and another for locally authenticated access.
  - Do not share the Company's passwords with anyone, including administrative assistants or secretaries. All passwords are to be treated as sensitive, confidential Company information.
  - Passwords should never be written down or stored on-line without encryption.
  - Do not reveal a password in email, chat, or other electronic communication.
  - Do not speak about a password in front of others.
  - Do not hint at the format of a password (e.g., "my family name")
  - Do not reveal a password on questionnaires or security forms
  - If someone demands a password, refer them to this document and direct them to the Information Security Department.
  - Always decline the use of the "Remember Password" feature of applications (e.g. Chrome, Microsoft Edge etc.).
  - If an account or password compromise is suspected, report the incident to the Information Security Department.

Violation of this policy may result in disciplinary action which may include performance sanctions; termination for employees and temporaries; a termination of employment relations in the case of contractors or consultants; dismissal for interns and volunteers. Additionally, individuals are subject to restriction or suspension of the Company's access privileges, as well as civil and criminal prosecution.

Password cracking or guessing may be performed on a periodic or random basis by the Information Security Department or its delegates. If a password is guessed or cracked during these exercises, the user/owner will be required to change it.

4. AMENDMENT TO THE POLICY

This policy document will be reviewed and updated at least once every three years or as and when needed.